Foundry Workspace Architecture Template

Section 1 — Apex Insurance Group Integrated Architecture Package

Project	Apex Insurance Group Integrated Architecture and Sign-off Package
Template Section	Section 1 — Foundry Workspace Blueprint
Learner Name	Dennis Lam
Deliverable	AI-Graded File Upload (PDF)

Section summary. One Foundry hub (hub-apex-foundry-prod, East US 2) carries shared governance only. Each business unit gets its own Project, resource group, model deployment and budget line, so the three data classifications never share a data connection, identity or cost meter. Operations builds and deploys in proj-apex-claims-processing; Legal and Finance only consume agents inside their own Projects. Claims agents authenticate with user-assigned managed identities and no stored credentials. Nothing is provisioned until the IT Security Director signs the approval block at the end of this section.

1. Business Unit Requirement Mapping

Business Unit	Data Classification	Access Level Required	Funding / Budget Line	Architecture Implication
Claims Processing (Operations)	**Restricted.** Sensitive policyholder and claims data: insured names, addresses, policy numbers, loss evidence, settlement and payment details.	Build-and-deploy: the team creates, tests and deploys agents itself.	Operations AI budget line, cost center CC-4100-OPS-CLAIMS. Pays for all Claims tokens, search, Document Intelligence and public-records API calls.	Dedicated Project proj-apex-claims-processing with its own resource group, model deployment and connections. Build rights stop at this Project boundary; the only internet egress is through APIM; agents use passwordless managed identities.
Compliance Monitoring (Legal)	**Confidential (Regulated).** Regulatory memos, policy amendments and state compliance guidelines, some privileged. The source SharePoint site is unmanaged (no labels, broad sharing).	Read-only query of a knowledge retrieval agent. No build, no configuration.	Legal AI budget line, cost center CC-2200-LEGAL-COMPLIANCE.	Dedicated Project proj-apex-compliance-legal. Consumer-only custom role. SharePoint content is remediated (labels, permissions) before it is indexed into a Legal-only search service. Zero connections to Claims resources.
Executive Reporting (Finance)	**Internal (Confidential, aggregated).** Aggregated claims metrics only; no claim-level or personal data.	Consumer-level query through Microsoft Teams. No build or deploy.	Finance budget line with a separate token-cost requirement, cost center CC-3300-FIN-EXECREPORT.	Dedicated Project proj-apex-exec-reporting with its own model deployment, so every Finance token is billed to CC-3300. Teams-published agent that reads only the aggregated semantic model.
Shared hub platform (CTO office)	**No business data.** Platform configuration and control-plane logs only.	Platform administration by the AI Platform Team, time-bound through PIM.	IT platform budget, cost center CC-1000-IT-AIPLATFORM.	Shared governance costs (network, policy, monitoring) are kept off the three business-unit budget lines.

Design rule derived from this mapping: one data classification = one Project = one resource group = one cost center = one Entra security group. Every boundary in Sections 2 to 4 inherits from this rule: an agent may only be grounded on data that sits in its own Project, and only Claims agents may call the external public-records API.

2. Hub-and-Project Hierarchy

Foundry Scope	Name	Business Unit / Workload	Data Boundary Rationale	Allowed Data Sources	Explicitly Excluded Data Sources
Hub	hub-apex-foundry-prod (East US 2; rg-apex-ai-hub-prod)	Enterprise shared governance boundary, owned by	Single US region for data residency. Managed virtual network in "allow only approved outbound" mode, private endpoints, public	Shared platform services only: platform Key Vault (no business-unit secrets), hub storage for system artifacts, container registry, log-apex-ai-platform for	**No hub-level data connections of any kind** (claims storage, policy database, public-records API,

Foundry Scope	Name	Business Unit / Workload	Data Boundary Rationale	Allowed Data Sources	Explicitly Excluded Data Sources
		the AI Platform Team (CTO office).	network access disabled, Entra ID-only authentication. Azure Policy initiative Apex-AI-Guardrails and Defender for Cloud AI threat protection are applied once and inherited by every Project.	control-plane diagnostics, default content-safety filters.	SharePoint, Power BI). Hub connections are inherited by every Project, so all data connections are created at Project scope.
Project	proj-apex-claims-processing (rg-apex-ai-claims-prod)	Claims Processing (Operations)	Holds the only Restricted data set and the only workload with build rights and internet egress. Isolating it keeps policyholder PII, claim files and the external API path inside one boundary that Legal and Finance identities cannot enter.	• claims-inbox container on stapexclaimsintake (claim PDFs) • Document Intelligence di-apex-claims-prod • sqldb-apex-policy read-only views vw_policy_coverage, vw_claim_history_36m • srch-apex-claims-prod with Foundry IQ knowledge bases kb-claims-intake-guide, kb-claims-policy-wordings, kb-claims-fraud-indicators, kb-claims-settlement-templates • Public-records API via apim-apex-integration-prod (with redis-apex-claims-prod response cache) • cosmos-apex-claims-prod, sb-apex-claims-prod, stapexclaimsout, lang-apex-claims-prod, aoai-apex-claims-prod	Legal SharePoint library and srch-apex-legal-prod; Finance semantic model, Fabric workspace and aoai-apex-finance-prod; any hub-shared data connection.
Project	proj-apex-compliance-legal (rg-apex-ai-legal-prod)	Compliance Monitoring (Legal)	Regulated, partly privileged content with a read-only audience. Because the source SharePoint site is unmanaged, content is remediated and indexed into a search service that only this Project can reach, so the agent cannot surface overshared or unrelated files.	SharePoint site **Apex Compliance Library** after remediation (Purview label "Confidential – Legal"; access limited to SG-Apex-Legal-ComplianceOfficers), indexed into Foundry IQ knowledge base kb-legal-regulatory-library on srch-apex-legal-prod; aoai-apex-legal-prod.	**All Claims data and resources:** claim PDFs, policy database, public-records API, claim case records, Claims agents and their configurations. Also the Finance semantic model.
Project	proj-apex-exec-reporting (rg-apex-ai-finance-prod)	Executive Reporting (Finance)	Aggregated-metrics-only boundary: the agent answers from a pre-built aggregate, never from claim records. Its separate budget line needs its own token meter.	Semantic model **Claims KPI – Aggregated** in Fabric workspace ws-apex-claims-analytics, reached through Fabric data agent fda-claims-kpi (read-only, user identity passthrough, minimum cohort of 10 claims per cell); aoai-apex-finance-prod; publication to Microsoft Teams.	**Claims raw data** (claim PDFs, claim case records, policy database, public-records results); **Legal** regulatory library; any write-back or build tooling.

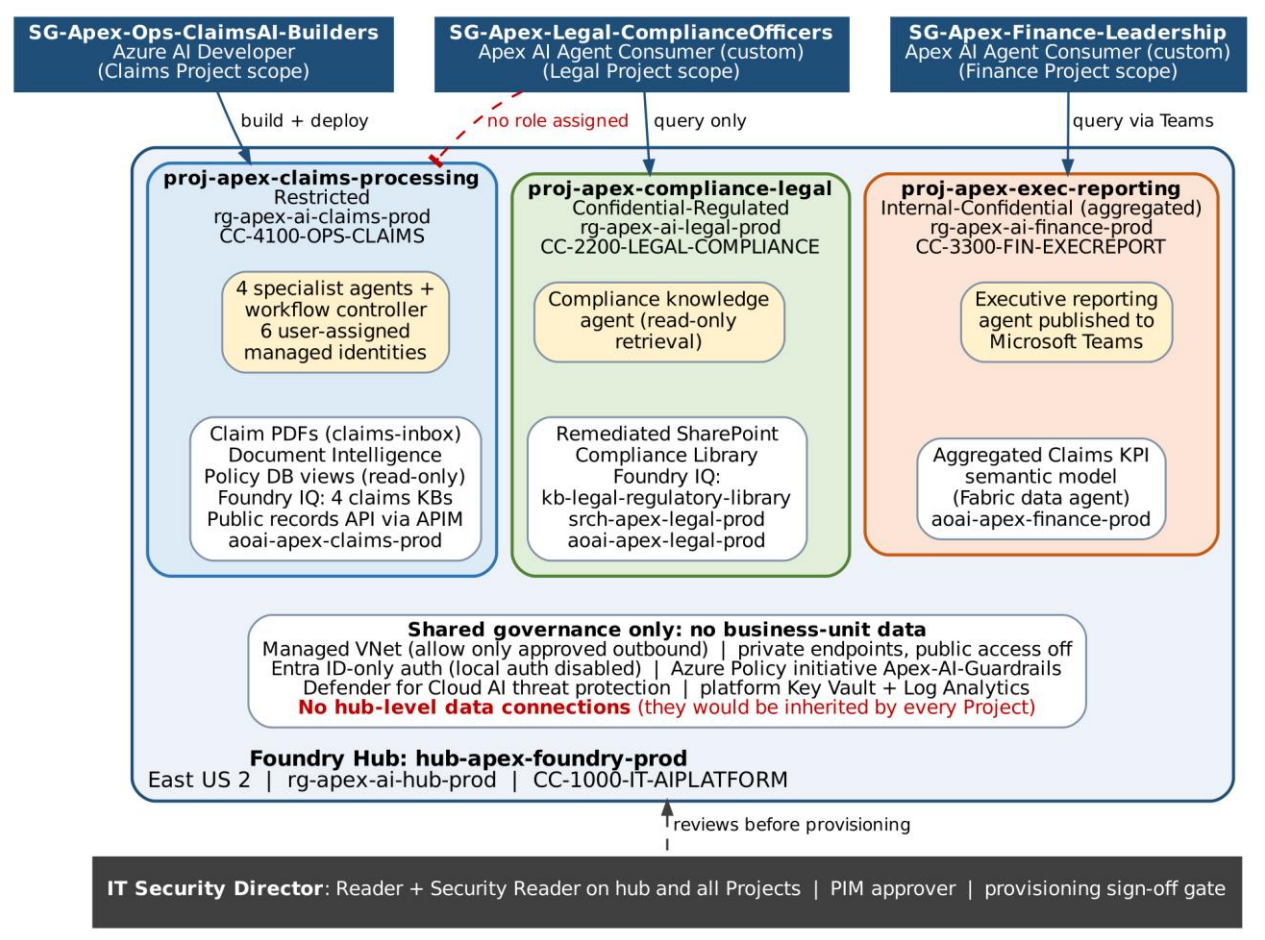


Figure 1. Hub-and-project hierarchy, data boundaries and team access for the Apex Foundry environment

3. RBAC Configuration

Team / Role Group	Foundry Scope	Required Access Level	Proposed RBAC Role or Equivalent	Allowed Actions	Denied Actions / Exclusions
Operations Team (SG-Apex-Ops-ClaimsAI-Builders)	proj-apex-claims-processing (Project scope)	Build-and-deploy	**Azure AI Developer** at Project scope. Production deployment rights are PIM-eligible (just-in-time, approval required), not standing.	Create, edit, test, evaluate and deploy Claims agents; manage Project-scoped connections; deploy models within the Project TPM quota; view Claims traces.	No role at hub scope (cannot change network, policy or hub connections). No access to the Legal or Finance Projects. Cannot assign roles (no Owner or User Access Administrator). Cannot read Key Vault secrets.
Legal Team (SG-Apex-Legal-ComplianceOfficers)	proj-apex-compliance-legal only	Read-only query	**Apex AI Agent Consumer** (custom role): Reader actions plus only the data actions needed to invoke a published agent. NotActions and NotDataActions exclude every write, delete, deployment and connection operation.	Query the compliance knowledge agent; open cited source documents they are already permitted to see in SharePoint.	**No Claims data or agent configuration access:** no role at Claims Project or hub scope. Cannot edit agents, knowledge sources, prompts or deployments.
Finance Team (SG-Apex-Finance-Leadership)	proj-apex-exec-reporting only	Consumer-level query	**Apex AI Agent Consumer** (custom role) at Project scope. Teams app availability limited to this group. Read	Ask questions of the pre-built executive reporting agent in Microsoft Teams.	No build or deploy privileges (no Azure AI Developer, no Contributor). No Foundry portal

Team / Role Group	Foundry Scope	Required Access Level	Proposed RBAC Role or Equivalent	Allowed Actions	Denied Actions / Exclusions
			permission on the aggregated semantic model only.		authoring. No claim-level data and no Legal library.
IT Security Director (SG-Apex-ITSec-Approvers)	Hub + all three Projects (read)	Sign-off / review	**Reader** at hub and Project scopes plus **Security Reader** at subscription scope. PIM approver for privileged role activations. Required reviewer on the production provisioning pipeline.	Review workspace, network, RBAC and identity design; view Defender for Cloud and Azure Policy compliance; approve or reject provisioning.	No data-plane access to claim files or legal documents. No operational deployment unless separately assigned.
AI Platform Team, CTO office (SG-Apex-AIPlatform-Admins)	Hub; Legal and Finance Projects	Platform administration (time-bound)	**Contributor** at hub scope, PIM-eligible only. **Azure AI Developer** on the Legal and Finance Projects to build and maintain their agents.	Provision Projects after sign-off; manage networking, policy and quotas; build the Legal and Finance agents on behalf of the read-only teams.	No standing privileged access. No role on the Claims Project data plane. All changes go through the same approval pipeline.

All assignments are made to Entra security groups, never to individuals, and are re-certified through quarterly Entra ID access reviews owned by each business-unit manager. Agents and service components hold no human roles; their access is defined only by the managed identities in item 4 below.

4. Managed Identity Design for Claims Processing Agents

Identity type: user-assigned managed identities (UAMIs). Six UAMIs are created in `rg-apex-ai-claims-prod`: one per Claims agent, one for the Claims Workflow Controller and one for the non-LLM Letter Rendering Service. User-assigned is chosen over system-assigned for three reasons: the identities exist before the agents, so the IT Security Director can review every role assignment (Table 4a) before anything is provisioned; they survive agent redeployment and versioning without new grants; and each agent has its own principal, which gives least privilege and a per-agent audit trail.

Passwordless authentication path: agent runtime → local managed-identity endpoint → Microsoft Entra ID issues a short-lived OAuth 2.0 access token for the target resource → the target service authorizes that principal through Azure RBAC (or a database role for Azure SQL). Tool code uses `ManagedIdentityCredential(client_id=<agent UAMI>)`. No connection strings, keys or certificates exist in code, configuration, prompts or agent instructions.

Downstream service access: least-privilege role assignments for each identity are listed in Table 4a below.

Why no stored credentials are required:

- Tokens are issued by Entra at run time, expire on their own and are rotated by the platform, so there is nothing to store, rotate or leak.
- Key-based access is switched off and enforced by Azure Policy deny rules: `disableLocalAuth` on AI Services, Document Intelligence, Language, Service Bus and Cosmos DB; `allowSharedKeyAccess = false` on storage; Entra-only authentication on Azure SQL.
- The one third-party secret, the public-records vendor API key, never reaches an agent. It lives in `kv-apex-claims-prod` and is read only by APIM's own system-assigned identity (Key Vault Secrets User) through a Key Vault-backed named value. Agents call APIM with their Entra token, which the `validate-jwt` policy checks.
- Agent-to-agent calls use the same pattern: bearer tokens from UAMIs, never shared keys (package Section 3, A2A authentication).

Table 4a. Managed identity role assignments for the Claims Processing agents (reviewed by the IT Security Director before provisioning)

Managed identity	Used by	Downstream resource	Role and scope (least privilege)
uami-claims-intake	Claim Intake / Extraction Agent	stapexclaimsintake / claims-inbox; di-apex-claims-prod; srch-apex-claims-prod	Storage Blob Data Reader (container); Cognitive Services User; Search Index Data Reader on kb-claims-intake-guide index
uami-claims-policy-xref	Policy Cross-Reference Agent	sqldb-apex-policy; srch-apex-claims-prod	Entra contained database user in role policy_xref_reader (SELECT on vw_policy_coverage only); Search Index Data Reader on kb-claims-policy-wordings
uami-claims-fraud-risk	Fraud and Risk Specialist	apim-apex-integration-prod (/public-records/v1); sqldb-apex-policy; srch-apex-claims-prod	Accepted by APIM validate-jwt for GET operations only; SELECT on vw_claim_history_36m only; Search Index Data Reader on kb-claims-fraud-indicators. **No write role anywhere.**
uami-claims-settlement	Settlement Specialist	srch-apex-claims-prod; calculate_settlement tool endpoint	Search Index Data Reader on kb-claims-settlement-templates; Entra app role

Managed identity	Used by	Downstream resource	Role and scope (least privilege)
			Settlement.Calculate. No storage, payment or policy-system role.
uami-claims-workflow-controller	Claims Workflow Controller (orchestrator)	proj-apex-claims-processing agents; stapexclaimsintake; cosmos-apex-claims-prod; sb-apex-claims-prod; lang-apex-claims-prod; appi-apex-claims-prod; Settlement A2A endpoint	Apex AI Agent Consumer (Project scope, invoke only); Storage Blob Data Reader on claims-inbox (reads submission metadata); Cosmos DB Built-in Data Contributor (database claimsflow); Service Bus Data Sender and Receiver; Cognitive Services User (PII redaction); Monitoring Metrics Publisher; app role Handoff.Submit on the Settlement Specialist endpoint
uami-claims-letter-render	Letter Rendering Service (non-LLM)	cosmos-apex-claims-prod (pii-token-vault, claim-cases); stapexclaimsout / settlement-drafts	Cosmos DB Built-in Data Reader on the two containers; Storage Blob Data Contributor on container settlement-drafts only

5. FinOps Cost Isolation Specification

Named mechanism: Project-dedicated model deployments with mandatory cost-center tags, metered by one Azure Cost Management budget per budget line. Five controls make it work:

- **Dedicated token meter per budget line.** Each Project connects only to its own Azure OpenAI resource and deployment: `aoai-apex-claims-prod`, `aoai-apex-legal-prod` and `aoai-apex-finance-prod`, each in its business unit's resource group. Every token a Project consumes is billed to that resource, so no shared-deployment split or estimate is needed. Search, Document Intelligence and API Management usage follow the same per-resource-group pattern.
- **Cost-center tags enforced by Azure Policy.** `CostCenter`, `BusinessUnit`, `FoundryProject` and `DataClassification` are required (deny on create) in each resource group, and Cost Management tag inheritance is turned on so resource-group tags reach every usage record. Values: `CC-4100-OPS-CLAIMS`, `CC-2200-LEGAL-COMPLIANCE`, `CC-3300-FIN-EXECREPORT`; the hub uses `CC-1000-IT-AIPLATFORM`.
- **Token quota allocation as a hard ceiling.** Tokens-per-minute quota is assigned per deployment from the subscription's regional quota: Claims 300K TPM, Legal 80K TPM, Finance 30K TPM (initial sizing, revisited after 30 days of telemetry). A spike in one budget line cannot consume another line's capacity.
- **Azure Cost Management budgets, one per budget line, scoped to the resource group.** Alerts fire at 50%, 80% and 100% of actual monthly spend and at 110% of forecast, through action groups to that line's budget owner and the FinOps lead. Finance alerts go straight to the Finance budget owner. At 100% of forecast the AI Platform Team reviews quota with the owner; Claims processing is never shut off automatically, because it is business-critical.
- **Showback and chargeback.** A daily Cost Management export to `stapexfinops`, grouped by `CostCenter`, feeds the monthly FinOps report. Per-agent token counts (`gen_ai.usage.input_tokens` and `gen_ai.usage.output_tokens` span attributes defined in package Section 4) break Claims spend down by agent. Shared hub costs stay on `CC-1000-IT-AIPLATFORM` unless the CTO chooses to spread them with a Cost Management cost-allocation rule.

6. Security Sign-off Notes

Why the design is ready for IT Security Director review

- **Isolation by classification:** one Project per business unit, no hub-level data connections, and no Legal or Finance role at Claims scope (Figure 1 and item 3 above).
- **Least privilege:** three distinct access levels at Project scope. Production deployment and hub administration are PIM-eligible only, with IT Security as approver.
- **Passwordless:** six user-assigned managed identities with every role assignment listed in Table 4a. Key-based authentication is disabled by policy.
- **Network:** managed virtual network with approved outbound only. The only internet egress is APIM to the public-records vendor's domain.
- **Audit:** every Claims agent interaction is traced to `appi-apex-claims-prod` and exported daily to immutable storage `stapexclaimsaudit` in `rg-apex-ai-claims-prod` (package Section 4, Workflow Stabilization).
- **Cost:** a separate meter, quota and budget for each of the three budget lines (item 5 above).

Provisioning gate

The production environment of the Bicep deployment pipeline lists the IT Security Director as a required approver. No Azure resource in this design is created until the approval block below is signed.

Unresolved assumptions for the reviewer

- **A1:** East US 2 meets data-residency obligations for every state where Apex writes commercial property business.
- **A2:** The public-records vendor supports API-key authentication only. If it supports OAuth client credentials, APIM moves to a federated credential and the Key Vault secret is retired.
- **A3:** The Legal records owner completes SharePoint remediation (labels and permissions) before indexing. Legal agent go-live is blocked until then.
- **A4:** Cost-center codes and initial TPM quotas are placeholders until Finance and the AI Platform Team confirm them.
- **A5:** Audit retention of seven years is pending confirmation by Records Management.
- **A6:** User identity passthrough from Teams to the Fabric data agent works for all Finance users under current licensing.

Workspace design approval (required before any environment is provisioned)

Approver	Name	Decision	Signature and date
IT Security Director		☐ Approve ☐ Approve with conditions ☐ Reject	
Chief Technology Officer (sponsor)		☐ Approve ☐ Approve with conditions ☐ Reject	

Submission Checklist

☑ Three business units are mapped to distinct Projects with classification-based rationale.

☑ Operations, Legal, and Finance have different access levels at correct scopes.

☑ Legal cannot access Claims data or agent configurations.

☑ Finance has consumer-level access only and cannot build or deploy.

☑ Claims Processing agents use passwordless managed identity authentication.

☑ FinOps mechanism is specifically named and applies across all three budget lines.